

Microsoft's secure browser

Including tracking protection and control over ActiveX filtering, Microsoft Internet Explorer 9 increases the browsing security.

Security play

"Kaspersky Small Office Security" gives small offices a virus free, spyware free environment along with protection from malicious software, managed from a single PC

Vaibhav Kaushal

readersletters@thinkdigit.com

Be it mundane tasks such as checking email, sending messages to friends, or online trading where millions are at stake, the web knits it all together. A minute of service disruption and the fairy-tale transfigures into nightmare. Hackers have always been targeting the bull's eye, exploiting the tiniest loophole in the web and make it all go kaboom. All this was inception ever since

base in the form of a query. The database replies back and the server determines whether the login was successful or not.

A simple line in PHP for building the database query from user input would be:

```
$query = "SELECT userid
FROM passwords WHERE
username='$username' and
password='$password'";
```

Here, we assume that the variables \$username and \$password already have the necessary values from the form. Assuming that you entered username and password as

such a password and report accordingly, resulting in a failed login.

Now, let's get innovative and enter the username as madman and type the following in the password column:

```
madman' OR password like
'% ' AND username='madman';--
```

Considering the way it is working, the server will create a query like:

```
SELECT userid FROM user_
table WHERE username='madman'
AND password='madman' OR
password like '% ' AND
username='madman';--;
```

WARNING!

The deeper, darker secrets behind the web, revealed.

@ Risk – Files, Fate and Fortune

it began getting un-blurred before the common men. We show you some of the simple but important tricks which can be used to make the web a scary place.

Just as with other arenas of hacking, web hacking too have some of its own moves. We'll show you a few.

SQL Injection – Anaesthesia for the DB

In the early days, developers used Microsoft FrontPage to design web sites. Today, we want web sites to have that human accent, understand what we need, and obey our commands. Almost every web-site you visit is run over some program which receives your requests, analyses it and produces a web page. PHP, ASP, NET, Python and Java are some of the well-known languages used for server side scripting. Along with a language, a dynamic web site also uses a database.

To read and write data from the database, one needs to use a language called Structured Query Language or SQL for short. Whenever you enter data in a form and 'submit' it, the request is converted into an SQL query, which is then sent to the database. For example, if you enter your username and password and 'sign in', they are sent to the data-



base and the table where the usernames and passwords are stored is user_table, the query would look like:

```
SELECT userid FROM user_
table WHERE username='madman'
AND password='madman';
```

Assuming the password was correct, the database will return one row containing one column with the userid of the user. If you entered a wrong password such as random, the database will not be able to find the username with

Noticed, the double dash, eh? The database ignores anything after the double dash (--) characters in an SQL query. This means that the above query will request the database to search for a user with username madman, and password also madman or search for a user with any password, but username madman. In such a case, the database basically searches only for a user whose username is madman and returns his userid. Oops!